Risk Register

R-001

Related Control ID: CTL-05 **Status:** Open

Risk Scenario: Unauthorized use of a privileged account could provide administrative access to systems supporting payment processing.

Cause / Gap: PA-010 has an unassigned owner and missing approval reference; MFA enforcement and its login outcome are unknown. PA-012 has unclear ownership, no supplied approval record, and an undocumented authentication method.

Business Impact: Unauthorized administrative access could expose sensitive information, alter system configurations, or disrupt payment-processing operations.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
3	5	15	High

Residual Likelihood	Residual Impact	Residual Score	Residual Level
3	5	15	High

Existing Safeguards: PA-001–PA-009 have named owners, approvals, and MFA enforcement recorded. PA-010 has MFA configured, but enforcement is unknown. These records do not establish effective safeguards for PA-010 or PA-012.

Score Rationale / Uncertainty: Likelihood 3 reflects plausible privileged-account misuse while authorization and authentication safeguards remain uncertain. Impact 5 assumes administrative compromise could seriously affect sensitive systems and payments. Actual permissions, exposure, and safeguard effectiveness require verification; no residual reduction is credited.

Treatment: Reduce

Remediation: Assign and validate PA-010 ownership and approval; verify and enforce applicable MFA. Validate PA-012 authorization, ownership, and service-account authentication safeguards. Retain supporting configuration and authentication records.

Evidence References: E-005-01; E-005-02; E-005-03; E-005-05

Owner: Identity and Access Management / Privileged Access Owner **Target Date:** 11/13/2026

R-002

Related Control ID: CTL-03 **Status:** Open

Risk Scenario: Incomplete oversight of the critical payment processor could leave vendor deficiencies or incident-response responsibilities unresolved, disrupting payment services or delaying incident response.

Cause / Gap: The processor is classified Critical, but its current assurance report is requested and not attached. Incident-notification terms remain Open without documented risk acceptance.

Business Impact: A processor outage or security incident could disrupt transactions and create financial, operational, and reputational harm.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
3	5	15	High

Residual Likelihood	Residual Impact	Residual Score	Residual Level
3	5	15	High

Existing Safeguards: The processor is included in the vendor inventory as Critical. Security owns the assurance review, and Legal / Security owns notification terms. The review remains In progress and the terms action remains Open.

Score Rationale / Uncertainty: Likelihood 3 reflects plausible vendor-related disruption with incomplete assurance and unresolved notification terms. Impact 5 assumes the critical processor dependency could materially interrupt payments. No complete vendor population, contractual detail, or verified safeguard effectiveness supports a residual reduction.

Treatment: Reduce

Remediation: Obtain and evaluate the processor’s current assurance report. Resolve incident-notification terms or document an authorized risk decision. Define owners and target dates for remaining follow-up.

Evidence References: E-003-01; E-003-02

Owner: Security, with Legal/Security support for incident notification terms. **Target Date:** 11/27/2026

R-003

Related Control ID: CTL-02 **Status:** Open

Risk Scenario: A CI/CD platform without clear ownership or review accountability could permit unauthorized or insecure changes to payment code.

Cause / Gap: The CI/CD platform is inventoried as able to change payment code, but its owner and last-review date are blank. Complete inventory coverage is not established.

Business Impact: Unauthorized or insecure payment-code changes could disrupt transaction processing, expose information, or cause financial and reputational harm.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
3	5	15	High

Residual Likelihood	Residual Impact	Residual Score	Residual Level
3	5	15	High

Existing Safeguards: The inventory identifies the CI/CD platform and its payment-code function. It does not establish assigned ownership or completed review for that platform.

Score Rationale / Uncertainty: Likelihood 3 reflects plausible misuse or unmanaged change where CI/CD accountability is missing. Impact 5 assumes deployment capability could affect payment-code security or availability. Actual access, technical safeguards, review history, and complete inventory coverage are unverified.

Treatment: Reduce

Remediation: Assign a CI/CD asset owner. Complete and document an asset review, define periodic review requirements, and reconcile relevant assets to payment flows and administrative paths.

Evidence References: E-002-01

Owner: Engineering Leadership / Designated CI/CD asset owner **Target Date:** 11/27/2026

R-004

Related Control ID: CTL-04 **Status:** Open

Risk Scenario: Failure to reconcile termination records with account status could leave former personnel with unauthorized access to business systems or information.

Cause / Gap: USR-023 and USR-024 have Status Terminated, while their Approval field says Active in export. Both are explicitly Not reviewed in the quarterly sample, and follow-up is not attached. Actual enabled-account status is unverified.

Business Impact: Unauthorized access by former personnel could expose information, enable inappropriate activity, or disrupt business operations.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
4	4	16	High

Residual Likelihood	Residual Impact	Residual Score	Residual Level
4	4	16	High

Existing Safeguards: USR-001 and USR-002 have Approval Yes and Reviewed / Signed off statuses. The two former-user entries remain unreviewed, with unresolved account-state annotations and no supplied follow-up.

Score Rationale / Uncertainty: Likelihood 4 is a conservative estimate pending reconciliation of two terminated identities marked Active in export and explicitly unreviewed. Impact 4 assumes misuse could expose business information or disrupt relevant systems. Actual enabled state, permissions, and termination dates are unverified.

Treatment: Reduce

Remediation: Reconcile USR-023 and USR-024 to identity-provider and application account states. Remove access where no longer authorized, complete their reviews, and retain follow-up decisions and supporting records.

Evidence References: E-004-01; E-004-02

Owner: Access Management with HR and any relevant system owners **Target Date:** 11/13/2026

R-005

Related Control ID: CTL-06 **Status:** Open

Risk Scenario: Changes deployed without timely authorization, adequate testing, or appropriate emergency review could introduce insecure or unstable functionality into production.

Cause / Gap: CHG-101 records approval After deployment. CHG-102 test evidence is Missing. CHG-103 testing is Not shown and post-implementation review is not evidenced.

Business Impact: Insecure or unstable production changes could disrupt services, introduce vulnerabilities, or affect payment-processing operations.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
4	4	16	High

Residual Likelihood	Residual Impact	Residual Score	Residual Level
4	4	16	High

Existing Safeguards: CHG-100 records pre-deployment approval and testing, and CHG-103 follows an emergency path. The four-change summary does not establish consistent approval, testing, or emergency-review effectiveness. Referenced attachments were not supplied.

Score Rationale / Uncertainty: Likelihood 4 reflects late approval and incomplete testing/review records in the four-change sample. Impact 4 assumes production changes could materially disrupt payments. Residual likelihood is retained at 4, revised from 3: one complete change does not justify a reduction. This is a conservative qualitative estimate.

Treatment: Reduce

Remediation: Require normal-change approval before deployment and retain testing records. Obtain CHG-102/103 testing and CHG-103 emergency-review evidence. Investigate CHG-101 approval timing and document resolution of the sampled exceptions.

Evidence References: E-006-01; E-006-02

Owner: Change management owner, accompanied with Engineering support **Target Date:** 11/27/2026

R-006

Related Control ID: CTL-07 **Status:** Open

Risk Scenario: Unresolved vulnerabilities and incomplete scanning coverage could leave payment-supporting systems exposed to exploitation and unauthorized access.

Cause / Gap: VUL-01 and VUL-02 are High and Open. VUL-02 has an October 1 target and is marked overdue. The Admin host is outside scan scope. VUL-03 has an expired exception with no recorded reassessment.

Business Impact: Exploitation could compromise sensitive systems or information, disrupt payment services, and cause financial, operational, and reputational harm.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
4	5	20	Critical

Residual Likelihood	Residual Impact	Residual Score	Residual Level
4	5	20	Critical

Existing Safeguards: Payment API and Cloud DB are recorded as scanned. VUL-01 has an assigned ticket and an October 20 target, which was not overdue at the October 15 cutoff. VUL-02 is overdue; full scan coverage and remediation closure are unverified.

Score Rationale / Uncertainty: Likelihood 4 reflects open High findings, overdue VUL-02, and an expired exception. Impact 5 assumes exploitation of the payment API or Cloud DB could severely affect information or payments. Findings are assessed at the declared October 15 cutoff; exploitability, scan dates, full coverage, and later remediation remain unverified.

Treatment: Reduce

Remediation: Resolve or formally mitigate VUL-02 and document a current target. Verify VUL-01’s outcome against its October 20 target. Confirm the Admin host’s relevance and include it in scanning where required. Reassess VUL-03 and document any renewed exception approval and safeguards.

Evidence References: E-007-01; E-007-02

Owner: Vulnerability Management Owner with affected system owners **Target Date:** 11/13/2026

R-007

Related Control ID: CTL-08 **Status:** Open

Risk Scenario: Incomplete security logging and unsupported alert-triage decisions could delay incident detection, investigation, and response.

Cause / Gap: Database logging, centralization, and retention are Unknown. The Support console has a row marked Not listed / Check scope. High-severity ALT-01 is Closed benign with No supporting notes.

Business Impact: Delayed detection or investigation could allow an incident to continue, affecting payment services, sensitive information, or business operations.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
3	5	15	High

Residual Likelihood	Residual Impact	Residual Score	Residual Level
3	5	15	High

Existing Safeguards: Payment API and identity provider are recorded as logging centrally with 90-day retention. ALT-02 is marked Investigated / Analyst notes attached, but those notes were not supplied separately. Actual logging and review effectiveness remain unverified.

Score Rationale / Uncertainty: Likelihood 3 reflects plausible delayed detection where coverage is unknown and a High alert lacks supporting closure notes. Impact 5 assumes a prolonged incident affecting critical payment systems could have severe consequences. No undetected breach is established, and actual logging, retention, and review quality remain unverified.

Treatment: Reduce

Remediation: Obtain ALT-01 investigation rationale and notes. Verify database logging and Support console scope/configuration. Define retention requirements and test actual retention. Inspect referenced analyst notes and representative source logs.

Evidence References: E-008-01; E-008-02

Owner: Security Operations / Logging and Monitoring owner **Target Date:** 11/27/2026

R-008

Related Control ID: CTL-09 **Status:** Open

Risk Scenario: Incomplete incident follow-up, unresolved exercise actions, and generic processor-coordination procedures could delay containment, recovery, or external coordination.

Cause / Gap: INC-01 is Closed with root-cause analysis missing. TTX-01 is Completed, but two actions remain Open and no retest is recorded. Processor-coordination steps in the plan summary are generic.

Business Impact: Delayed or ineffective response could prolong service disruption, increase security exposure, and affect payment operations and stakeholder confidence.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
3	5	15	High

Residual Likelihood	Residual Impact	Residual Score	Residual Level
3	5	15	High

Existing Safeguards: The plan summary identifies response, escalation, and communication roles. A tabletop exercise is recorded as completed. Underlying incident, exercise, and action-closure records were not supplied.

Score Rationale / Uncertainty: Likelihood 3 reflects plausible response delays from incomplete coordination and follow-up. Impact 5 assumes a significant incident could severely disrupt payment services. Actual incident scope, action due dates, and response performance are unverified; Open actions are not automatically overdue.

Treatment: Reduce

Remediation: Document INC-01 root-cause analysis. Assign owners and dates for TTX-01 actions, retain closure evidence, and document a retest where appropriate. Specify processor contacts, escalation responsibilities, and coordination steps.

Evidence References: E-009-01; E-009-02

Owner: Incident Response Owner, with Security and payment processor relationship owners. **Target Date:** 11/27/2026

R-009

Related Control ID: CTL-10 **Status:** Open

Risk Scenario: Incomplete identification of sensitive-data flows and inadequate storage or retention safeguards could leave payment or customer information insufficiently protected.

Cause / Gap: One Support export path is unmapped. Analytics-store encryption at rest is Unknown / Not evidenced. The export sample lacks a retention date and notes two exports without approved retention rationale.

Business Impact: Inadequate protection could result in unauthorized disclosure, excessive retention, contractual or regulatory exposure, and reputational harm.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
3	5	15	High

Residual Likelihood	Residual Impact	Residual Score	Residual Level
3	5	15	High

Existing Safeguards: The primary payment flow is described and the processor connection is listed as TLS 1.2+. These summaries do not establish complete flow coverage, analytics encryption at rest, or effective export-retention controls.

Score Rationale / Uncertainty: Likelihood 3 reflects plausible data exposure with an unmapped flow and incomplete retention documentation. Impact 5 assumes sensitive payment or customer information could be extensively compromised. Data volumes, technical settings, and actual retention execution are unverified; Unknown encryption does not mean encryption is disabled.

Treatment: Reduce

Remediation: Map the Support export path and data elements. Inspect processor and analytics encryption configurations. Approve export-retention requirements and dates, verify execution, and retain supporting records.

Evidence References: E-010-01; E-010-02

Owner: Data Protection Owner, with Analytics and Support Operations owners. **Target Date:** 11/27/2026

R-010

Related Control ID: CTL-11 **Status:** Open

Risk Scenario: Incomplete backup coverage or insufficiently validated restoration could delay recovery of critical systems after an outage or security incident.

Cause / Gap: Identity-configuration backup coverage is unknown. A Payment DB restore is recorded as successful but was not compared with an approved recovery-time objective. One of four administrators lacks recent access-review evidence.

Business Impact: Delayed recovery or information loss could prolong payment-service disruption and increase operational, financial, and reputational harm.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
3	5	15	High

Residual Likelihood	Residual Impact	Residual Score	Residual Level
3	5	15	High

Existing Safeguards: Daily backups for Payment database and Configuration store are reported as successful, as is one Payment DB restore. Complete coverage, measured recovery performance, and full administrator-review coverage are not established.

Score Rationale / Uncertainty: Likelihood 3 reflects plausible recovery difficulty where coverage and recovery performance are unverified. Impact 5 assumes critical payment systems could suffer prolonged outage or information loss. Summary successes do not establish full coverage or recovery capability; no backup failure or inappropriate access is proved.

Treatment: Reduce

Remediation: Verify identity-configuration backup coverage. Obtain dated backup and restore records and approved recovery objectives. Compare measured restore performance with those objectives. Complete the missing administrator review and document its outcome.

Evidence References: E-011-01; E-011-02

Owner: Backup and disaster recovery owner; with identity and system owners **Target Date:** 11/27/2026

R-011

Related Control ID: CTL-12 **Status:** Open

Risk Scenario: Unresolved reconciliation exceptions or insufficiently reviewed payment-routing changes could allow transaction errors or unauthorized changes to remain undetected.

Cause / Gap: REC-02 is Pending beyond target. REC-03 is Closed without a documented resolution reason. PAY-CHG-01 lacks independent-review evidence. Technical implementation evidence for transaction controls is limited.

Business Impact: Undetected errors or unauthorized routing changes could undermine transaction integrity, cause financial loss, disrupt payments, and damage customer trust.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
3	5	15	High

Residual Likelihood	Residual Impact	Residual Score	Residual Level
3	5	15	High

Existing Safeguards: The narrative describes authorization, transaction references, and reconciliation. REC-01 is recorded as resolved with a documented resolution. Consistent follow-up, independent routing-change review, and technical enforcement remain unverified.

Score Rationale / Uncertainty: Likelihood 3 reflects plausible undetected errors given delayed reconciliation and undocumented closure. Impact 5 assumes material payment-processing or routing errors could cause severe financial or service consequences. Transaction volumes, delay duration, technical enforcement, and actual independent review are unverified.

Treatment: Reduce

Remediation: Resolve REC-02 and retain dated follow-up. Document REC-03’s resolution reason. Obtain PAY-CHG-01 independent-review evidence or investigate the gap. Retain routing-change approvals and technical control-operation records.

Evidence References: E-012-01; E-012-02

Owner: Payment Operations Owner, with Change Management Support **Target Date:** 11/27/2026

R-012

Related Control ID: CTL-01 **Status:** Open

Risk Scenario: Unclear accountability and delayed governance follow-up could leave security and third-party risks unassigned, unmonitored, or unresolved.

Cause / Gap: The RACI records third-party risk ownership as Shared / TBD and Accountability unclear. The policy/action summary states that the access-policy review and a High-priority committee action are overdue; actual dates are not supplied.

Business Impact: Unresolved governance and vendor-risk issues could allow weaknesses to persist, increasing exposure to security incidents or operational disruption.

Likelihood 1-5	Impact 1-5	Inherent Score	Inherent Level
3	4	12	High

Residual Likelihood	Residual Impact	Residual Score	Residual Level
3	4	12	High

Existing Safeguards: Security leadership is assigned to Director Security, and the access policy is listed as Approved. Third-party accountability remains unclear, while policy review and committee follow-up have recorded exceptions.

Score Rationale / Uncertainty: Likelihood 3 reflects plausible unresolved risks from unclear accountability and recorded overdue actions. Impact 4 assumes governance weaknesses could materially affect security or operations. Actual due dates, policy requirements, and complete action tracking are unavailable, so lateness cannot be independently recalculated.

Treatment: Reduce

Remediation: Assign one accountable third-party risk owner. Obtain the policy and review schedule, complete the review, and close or formally reprioritize the committee action with an owner, target date, and documented approval.

Evidence References: E-001-01; E-001-02

Owner: Director Security, with assigned Third Party Risk Owner **Target Date:** 11/27/2026